PROYECTO FINAL - DEVSECOPS

IAM Secure

Informe técnico

Gobierno y gestión centralizada
de identidades y accesos

Prueba-ProyectoFinal | Grupo 1 | DEVSECOPS2026_2

AUTORES

Oscar Daniel Acosta

David Enrique Diaz

Ingrid Tatiana Vesga

Jean Carlos Almenarez Ríos

Yeison Fabián Bernal López

ASIGNATURA

Seg en Entornos Cloud y Devops

14 de octubre de 2026 | America/Bogota

Corte de código: 61a1f7a | Alcance académico y local

Tabla de contenido

Los títulos y números de página son enlaces internos. Las referencias identificadas como [R1]-[R16] enlazan las evidencias de origen.

1. Introducción 3

1.1 Contexto, problema y alcance . . . 3
1.2 Objetivos y metodología . . . 3
1.3 Corte técnico y límites . . . 3

2. Arquitectura y UML 4

2.1 Responsabilidades, datos y decisiones . . . 4
2.2 UML de componentes . . . 5
2.3 UML de despliegue y exposición . . . 6
2.4 UML de secuencia de autenticación . . . 7
2.5 UML de casos de uso e historia funcional . . . 8
2.6 Perfil seguro de laboratorio local . . . 9

3. Threat Dragon y STRIDE 10

3.1 Modelo de contexto y límites de confianza . . . 10
3.2 DFD nivel 1 y persistencia lógica . . . 11
3.3 Inventario STRIDE: T01-T10 . . . 12
3.4 Inventario STRIDE: T11-T20 . . . 13
3.5 Riesgo residual y tratamientos prioritarios . . . 14

4. Pipeline DevSecOps 15

4.1 Integración continua y políticas de bloqueo . . . 15
4.2 ZAP automatizado y Quality Gate Sonar . . . 16
4.3 Publicación y despliegue simulado . . . 17

5. Resultados y tabla de hallazgos 18

5.1 Resultados cuantitativos y procedencia . . . 18
5.2 Hallazgos de calidad y riesgos no aceptados . . . 19
5.3 Hallazgos de alcance y deuda de cierre . . . 20
5.4 Tratamientos verificados en laboratorio . . . 21
5.5 Cobertura, integridad y evidencias consultadas . . . 22

6. Conclusiones 23

6.1 Balance técnico . . . 23
6.2 Cierre priorizado y alcance de la entrega . . . 23

1. Introducción

1.1 Contexto, problema y alcance

IAM Secure es una plataforma académica para centralizar identidades y accesos. Resuelve la administración de usuarios, credenciales, MFA, roles, compañías, sesiones y concesiones de vistas. El proyecto incorpora aprovisionamiento desde Excel y auditoría, y integra controles de seguridad en construcción, pruebas y despliegue [R1, R2].

La jerarquía separa ADMIN_TI, ADMIN_SOPORTE y líderes de Facturación, Logística y Gestión Humana. Las compañías delimitan el alcance de administración y consulta. Las tarjetas del portal son vistas académicas de referencia: no constituyen sistemas de facturación, logística o recursos humanos.

1.2 Objetivos y metodología

Objetivo general. Implementar y verificar una solución de identidad y acceso con autenticación reforzada, autorización en servidor y un ciclo DevSecOps trazable.

Objetivos específicos. Aplicar RBAC y alcance por compañía; permitir sesiones revocables y MFA obligatorio; procesar cargas XLSX con validación previa; conservar auditoría; modelar amenazas mediante Threat Dragon/STRIDE; y automatizar controles en GitHub Actions.

La evaluación contrasta código, diagramas, reportes versionados y ejecuciones identificadas. Cada cifra se atribuye a su commit, fecha y entorno. No se suman suites solapadas. El CI directo del espejo espera el Quality Gate de Sonar; el check externo confirma su aprobación.

1.3 Corte técnico y límites

Elemento	Corte utilizado
Código evaluado	61a1f7a en master del espejo; CI, Sonar y laboratorio de la misma revisión. Documentación posterior conserva el recibo y corte probado.
CI del espejo	Run 38638956405: 32/32 trabajos aprobados y check externo Sonar aprobado.
ZAP final	Staging construido desde 61a1f7a: GET-only, 7 scans y 39 operaciones/API-rol.
Sonar actual	Quality Gate passed: nueva 85,6 % >= 80 %, global 56,7 %. Umbrales preservados; no equivale a cobertura integral.
Evidencia histórica	Cobertura local, instalación limpia, publicación 1.0.0 y CD conservan sus cortes propios.

El informe no acredita producción real con TLS/HA ni ausencia global de vulnerabilidades. PostgreSQL es compartido; el conector Sync y las vistas de negocio mantienen alcance académico.

2. Arquitectura y UML

2.1 Responsabilidades, datos y decisiones

La solución utiliza React/Vite y Nginx para la interfaz, FastAPI/Python para APIs y PostgreSQL 17 para persistencia. Dos workers gestionan sincronización y entrega de auditoría. La carga Excel pertenece a Identity; la grilla reutiliza el frontend en un origen separado [R2].

Componente	Responsabilidad y relación
Identity	Autoridad de identidades, contraseña, MFA, JWT/sesiones, roles, compañías y carga Excel. Aprovisiona permisos iniciales del líder.
Permissions	Catálogo cerrado de nueve vistas; concesiones por usuario/compañía. Consulta /auth/me en Identity y vuelve a comprobar el alcance en PostgreSQL.
Frontend / grilla	Panel, portal, carga y administración de vistas. La grilla recibe una sesión temporal por un canal validado y la conserva en memoria.
Sync Worker	Reclama sync_jobs, reintenta y recupera trabajos; conector externo simulado.
Audit Dispatcher / Service	Outbox y entrega con token interno; persistencia sanitizada, idempotencia por event_uuid y protección append-only.
PostgreSQL	Identidad, organización, sesiones/MFA, colas, auditoría, permisos y lotes/filas Excel. Volumen persistente.

Las decisiones principales son autorización en servidor, sesiones persistentes revocables, separación de responsabilidades y outbox transaccional donde está implementado. La firma JWT por sí sola no concede acceso: se comprueban usuario, roles, compañía y sesión vigentes. Un permiso ausente o deshabilitado se deniega.

Límite arquitectónico

D1-D6 son particiones lógicas de una instancia PostgreSQL. El perfil seguro separa logins/ACL por servicio, sin aislamiento físico por microservicio. El Compose de desarrollo conserva usuario administrativo y HTTP; la aceptación residual y la adopción del perfil seguro se revisan separadamente [R14, R15].

2.2 UML de componentes

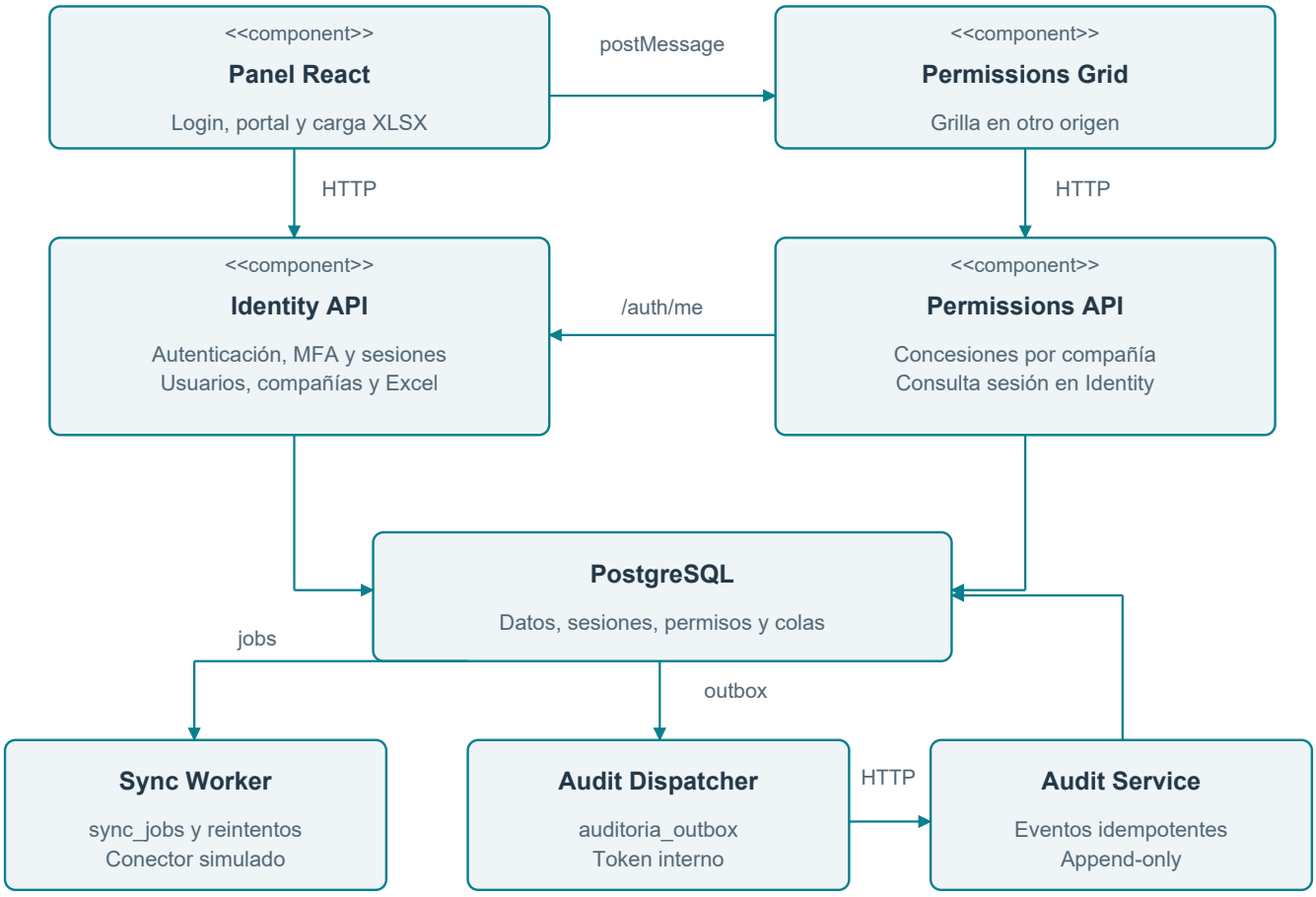


Figura 1. Vista UML de componentes simplificada para el informe. Fuente: COMPONENTES.md y arquitectura [R2]. Las flechas representan dependencias y flujos principales; no muestran todos los endpoints.

Identity mantiene la autoridad de autenticación; Permissions no replica el JWT_SECRET ni la clave de cifrado MFA. La comprobación online de sesión permite que revocar una sesión o retirar alcance tenga efecto sin esperar a la expiración criptográfica del token.

La creación individual y la carga Excel reutilizan el mismo aprovisionamiento. Los permisos iniciales se guardan con el usuario; los duplicados y reintentos no reactivan excepciones. SMTP está fuera de la transacción de PostgreSQL y no garantiza entrega exactamente una vez.

Auditoría y trabajo asíncrono

Las dos rutas de reset MFA guardan el evento sanitizado en la misma transacción que eliminan MFA y revocan sesiones/desafíos. Si INSERT o COMMIT falla, se revierte el conjunto. El dispatcher retiene y alerta fallos terminales. Otros eventos históricos best-effort conservan límites [R14, R15].

2.3 UML de despliegue y exposición

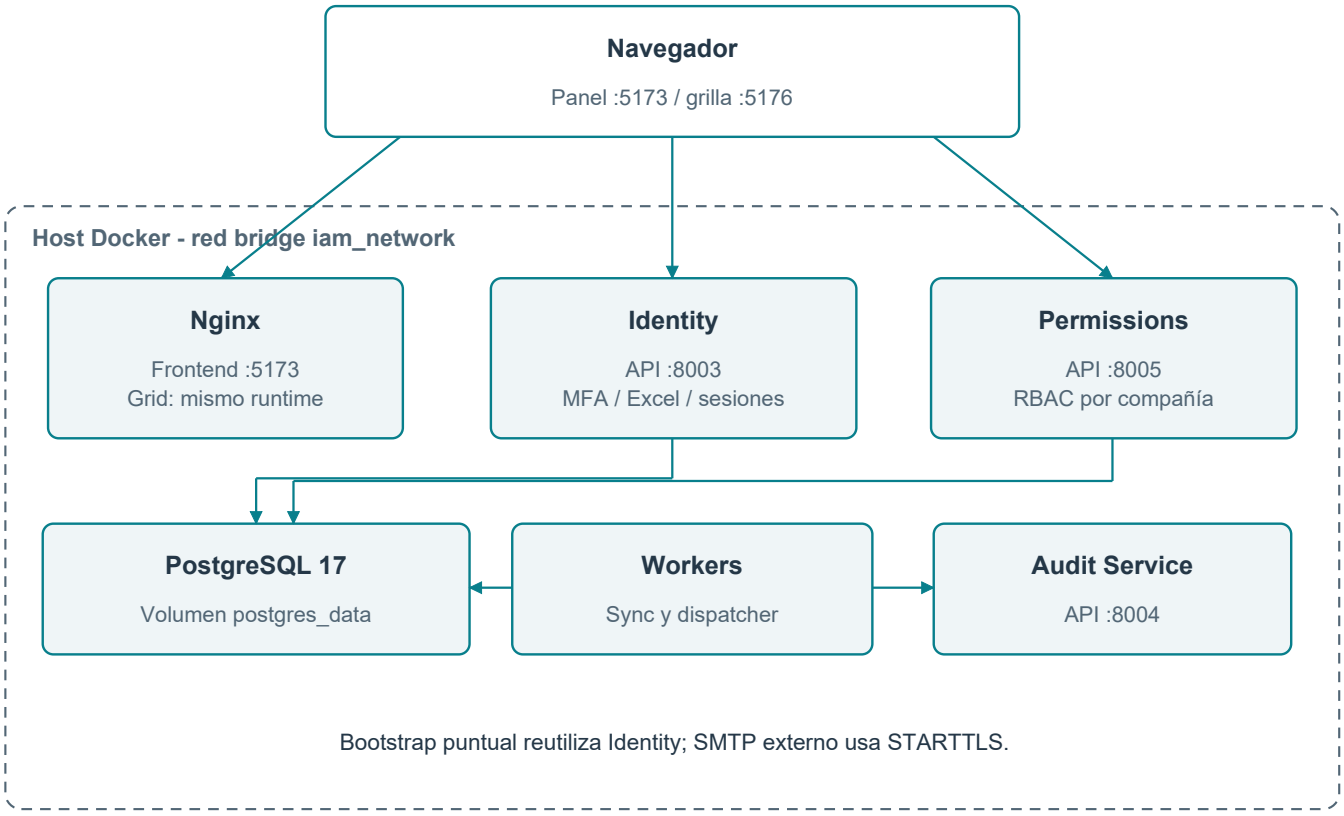


Figura 2. Despliegue local de desarrollo. Redibujo de DESPLIEGUE.md [R2]; no representa la topología de producción simulada del runner.

Servicio	Puerto host	Observación
Frontend / Identity	5173 / 8003	Publicación de desarrollo en host; sin TLS acreditado.
Permissions Grid / API	127.0.0.1:5176 / :8005	La grilla reutiliza Nginx/frontend; APIs conservan autorización.
Audit / PostgreSQL	127.0.0.1:8004 / 5433	PostgreSQL publica 5433 en desarrollo; volumen postgres_data.
Sync / dispatcher	Sin puerto host	Procesos Python; no requieren interfaz HTTP publicada.

El Compose local construye las aplicaciones desde fuente. Las imágenes Docker Hub 1.0.0 son una publicación histórica y no contienen todos los cambios posteriores. Git no transporta cuentas, secretos ni volúmenes.

2.4 UML de secuencia de autenticación

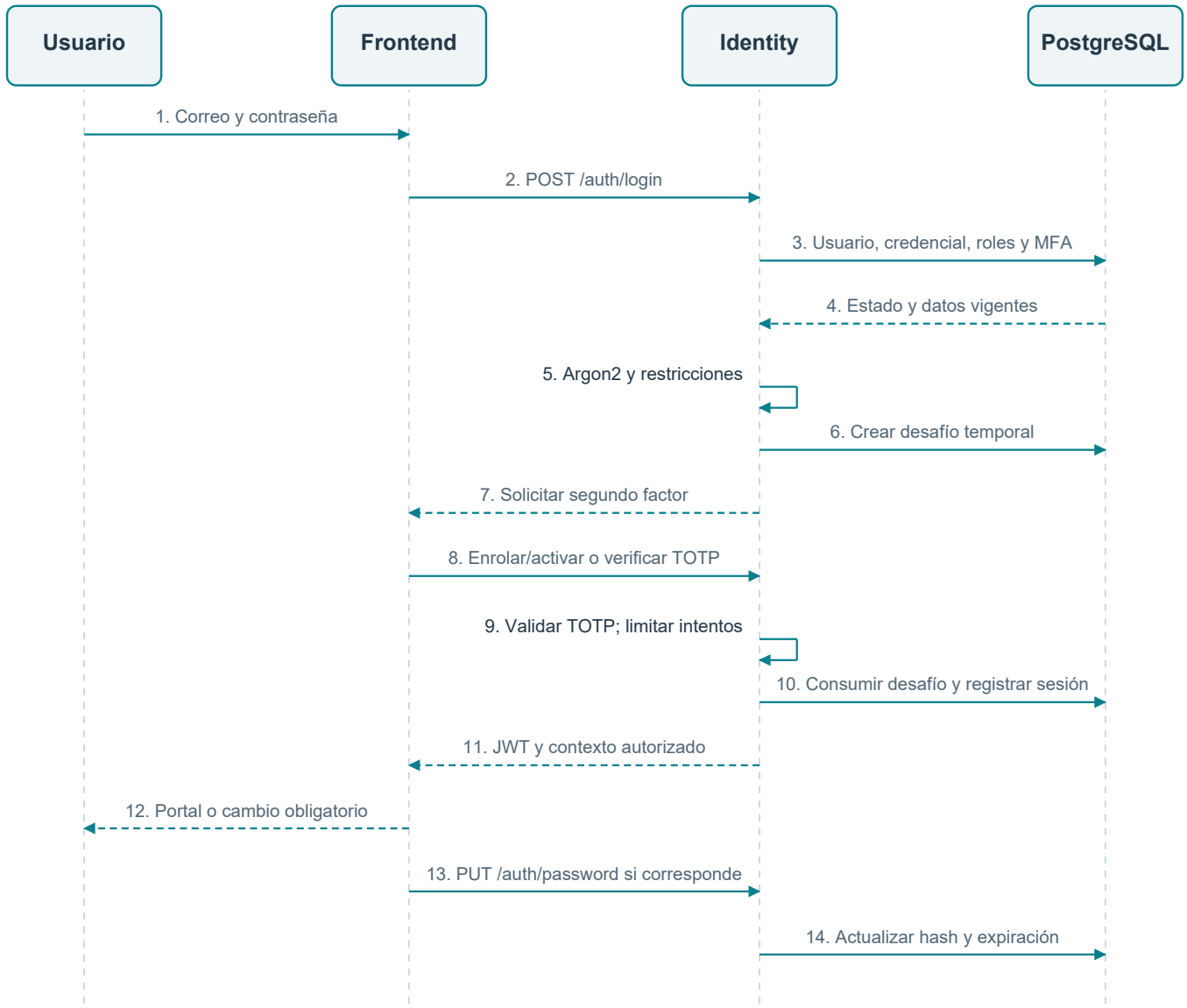


Figura 3. Secuencia resumida de primer factor, MFA, sesión y cambio obligatorio [R2]. La validación TOTP pertenece a Identity; el módulo MFA no se representa como microservicio independiente.

Con primer factor válido se crea un desafío aleatorio, con expiración, uso único e intentos limitados. Sin MFA activo se enrola y activa TOTP; con MFA activo se verifica el código. La sesión definitiva se emite después del segundo factor y se registra mediante jti en PostgreSQL.

Credenciales/estado inválidos, desafío expirado, TOTP incorrecto o falta de rol producen rechazo según el contrato. La sesión de contraseña temporal permanece restringida hasta completar el cambio. La inactividad predeterminada es de cinco minutos; frontend y API conservan comprobaciones propias.

2.5 UML de casos de uso e historia funcional

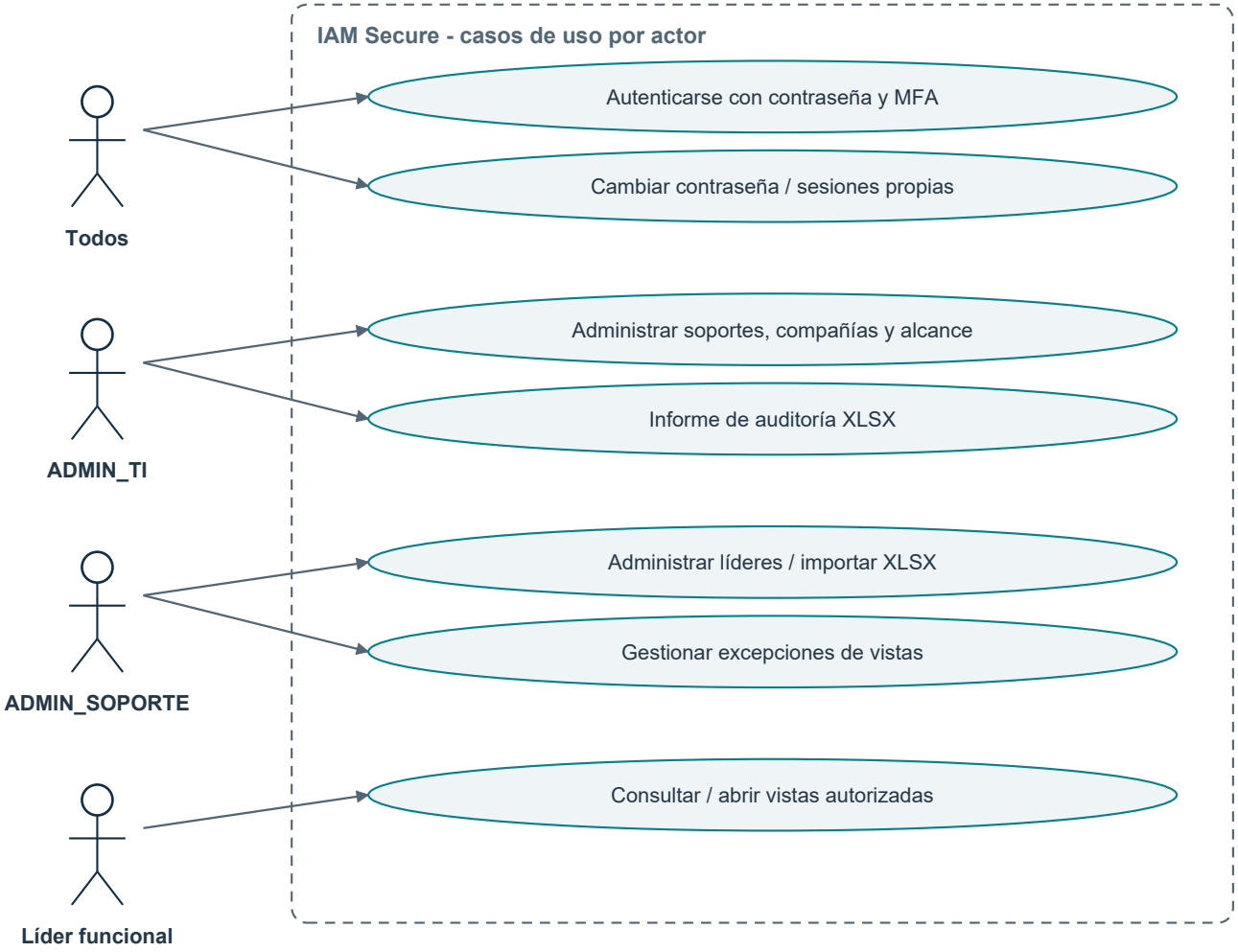


Figura 4. Casos de uso por actor, redibujados para lectura [R2]. Los líderes se distinguen por rol funcional y concesiones; un botón visible no sustituye autorización API.

Historia distinta de autenticación: ADMIN_SOPORTE valida un XLSX para una compañía activa asignada, confirma creación/envío, procesa filas válidas y exporta resultados. Después administra una excepción de vista desde la grilla y comprueba las opciones del líder. Revalidar un duplicado no modifica la cuenta ni reactiva permisos.

La validación previa no crea usuarios ni envía correo. La importación limita tamaño, filas y ZIP expandido; rechaza macros, fórmulas y vínculos externos según el parser. La ejecución por fila usa bloqueo y transacción, con estado persistido para consultar o retomar el lote.

El recorrido local aceptado utiliza una cuenta; ampliar varias filas con correos funcionales y preparar la presentación final son tareas distintas. Las pruebas CI con correo/API simulados no equivalen a SMTP real o un E2E completo.

2.6 Perfil seguro de laboratorio local

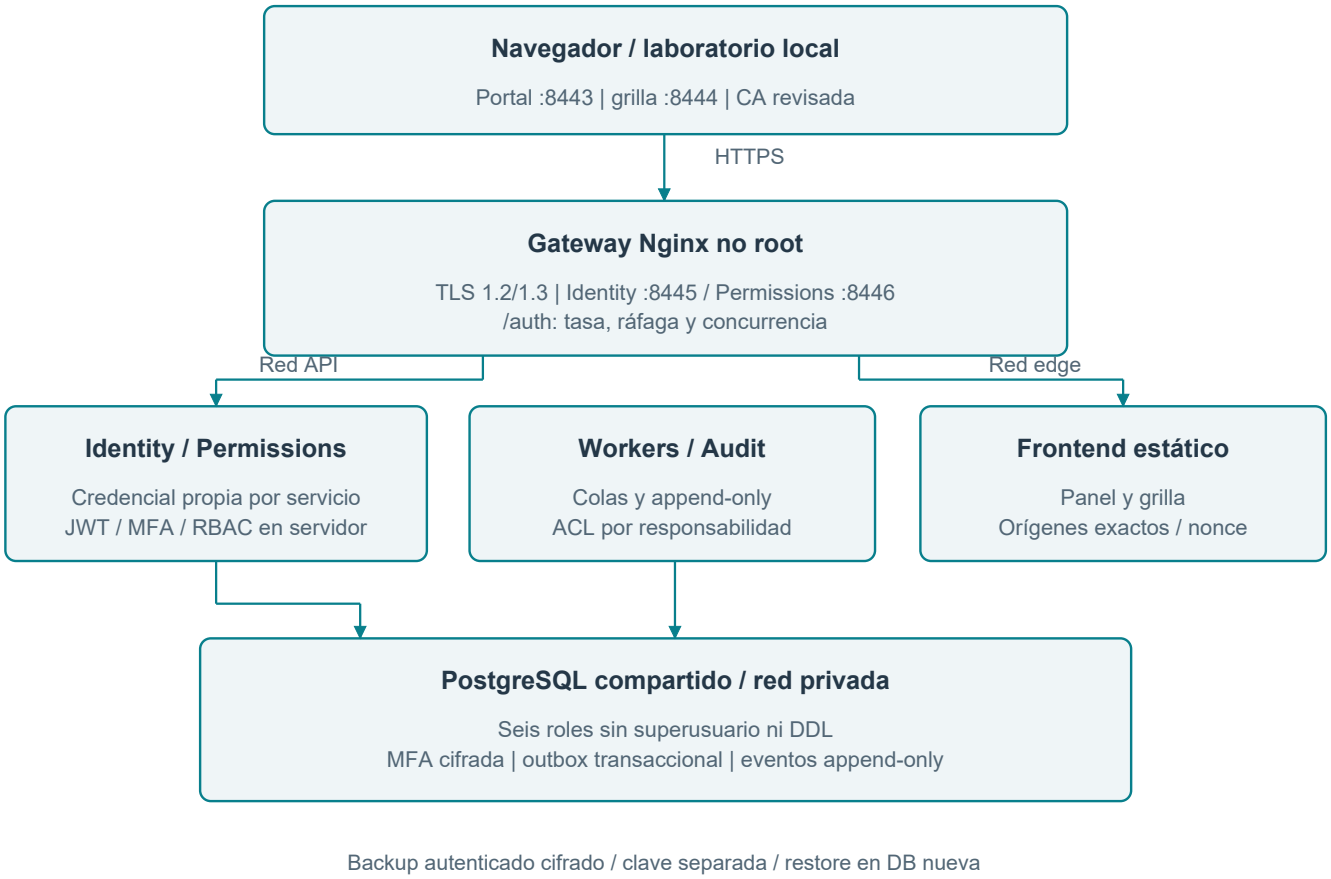


Figura 5. Despliegue alternativo probado con datos nuevos y sintéticos [R14, R15]. El gateway no recibe claves DB/JWT/MFA; PostgreSQL y APIs no publican puertos directos. No representa producción ni reemplaza el Compose de desarrollo por ejecutar una prueba.

El perfil construye imágenes desde el código evaluado, genera credenciales independientes y ejecuta bootstrap con iam_identity. La clave TLS PKCS8 se cifra y monta con su secreto de desbloqueo, en archivos privados. La CA de laboratorio no se instala automáticamente en el almacén de confianza del equipo.

Permissions mantiene locks mediante funciones fijas, con objetos cualificados y search_path seguro, sin UPDATE sobre identidades/compañías. Identity y Permissions insertan únicamente campos de evento y leen identificadores de outbox; no leen payloads ajenos ni asignan estado de entrega. Los workers solo actualizan sus columnas operativas.

> **Activación y límites**
>
> El 14 de octubre se activó el perfil seguro interactivo en localhost:8443-8446, con volumen nuevo y nueve servicios no root. La CA fue autorizada para el usuario Windows; desarrollo conserva HTTP y sus datos. Tráfico interno, custodia y aceptación residual mantienen límites distintos [R16].

3. Threat Dragon y STRIDE

3.1 Modelo de contexto y límites de confianza

Threat Dragon documenta el modelo as-is mediante DFD nivel 0 y 1 y amenazas T01-T20. Las exportaciones fueron revisadas visualmente el 13 de octubre de 2026 en la versión web 2.6.2-latest. El validador de esquema, referencias y paridad STRIDE complementa la revisión visual [R3].

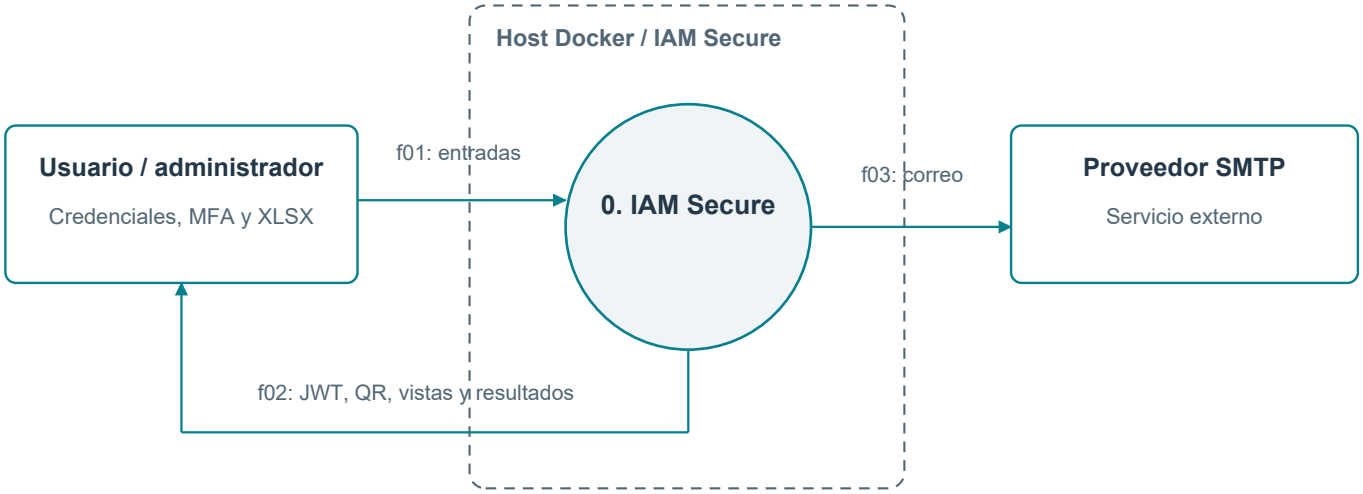


Figura 6. DFD nivel 0, redibujo vectorial del export de Threat Dragon [R3]. Se conserva proceso 0, entidades externas, flujos f01-f03 y límite Docker; no se añaden componentes.

Límite / activo	Implicación de seguridad
Navegador / APIs	Identidad, sesión, compañía y permiso deben comprobarse en servidor. El almacenamiento de sesión y el canal entre ventanas afectan T09/T18.
Host Docker / PostgreSQL	La red interna y las capacidades del contenedor no sustituyen TLS ni roles DB mínimos. Secretos y datos personales son activos, no valores del diagrama.
SMTP externo	STARTTLS implementado; la entrega de contraseña temporal y la falta de atomicidad con DB conservan limitaciones.
Cadena de suministro	Git, dependencias, runners e imágenes forman el alcance de T16 y los controles SAST/SCA/escaneo de imágenes.

3.2 DFD nivel 1 y persistencia lógica

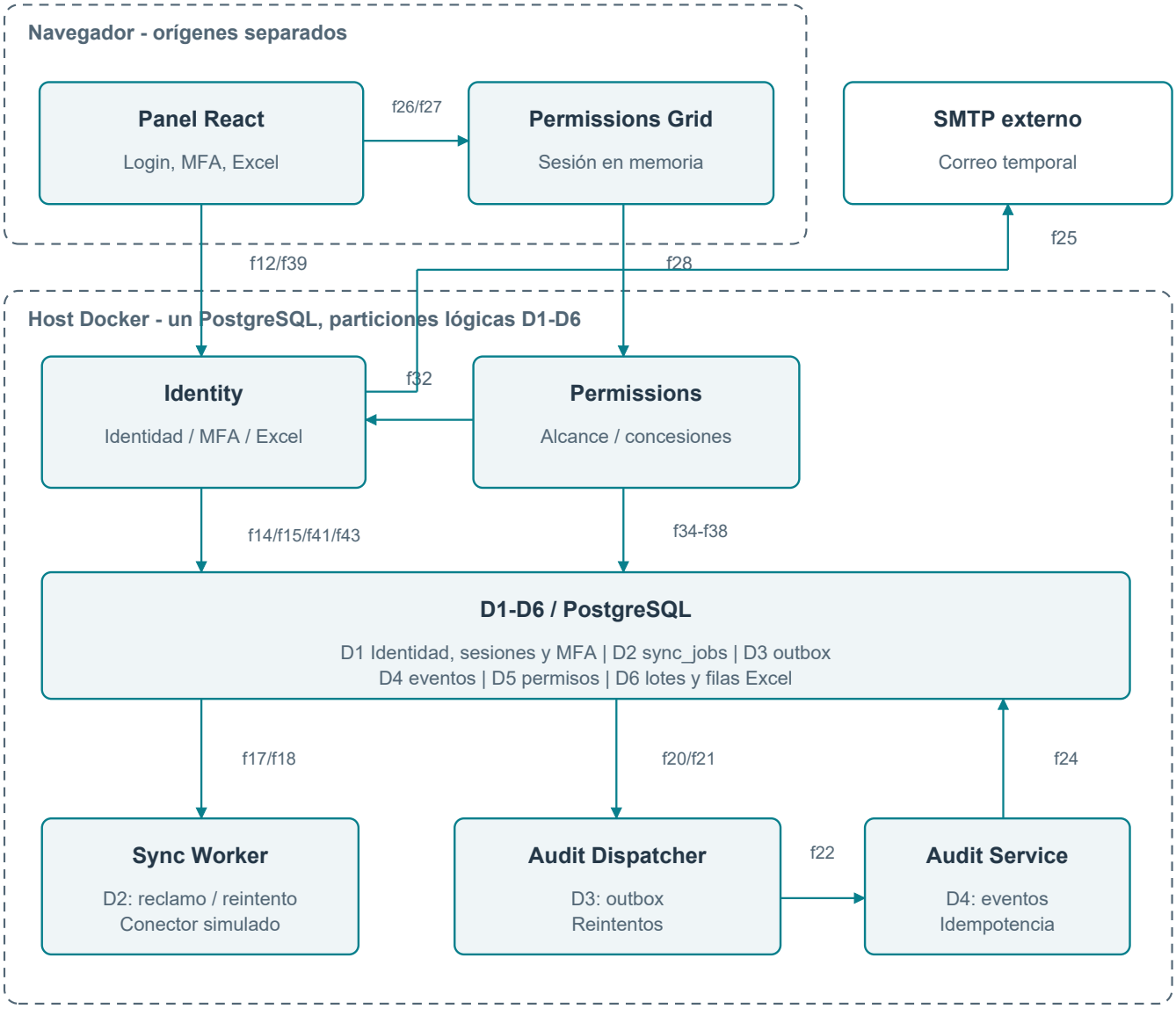


Figura 7. Vista sintética del DFD nivel 1 para lectura impresa. Fuente: modelo y export originales [R3]. Se agrupan D1-D6; los identificadores f representan flujos del modelo. El SVG original conserva todas las rutas y cruces.

El DFD as-is conserva panel/grilla y APIs del Compose de desarrollo. El canal postMessage verifica origen, ventana, nonce y expiración; no es un flujo HTTP. El perfil TLS alternativo de la figura 5 protege navegador/APIs y añade roles separados, sin cambiar automáticamente la aceptación ni los estados del modelo [R14, R15].

D1: identidad/sesiones/MFA/compañías; D2: sync_jobs; D3: auditoria_outbox; D4: auditoria_eventos; D5: permisos; D6: cargas y filas. Todos comparten PostgreSQL. El bootstrap es puntual y el conector Sync es simulado.

3.3 Inventario STRIDE: T01-T10

La severidad es la valoración del modelo, no un resultado de explotación. S: suplantación; T: manipulación; R: repudio; I: divulgación; D: denegación de servicio; E: elevación de privilegio. Los estados y decisiones se contrastaron con la aceptación humana [R3].

ID	Cat.	Amenaza	Sev.	Estado / residual
T01	S	Suplantación por robo de JWT	Alta	Open / aceptado local
T02	S	Suplantación del dispatcher	Alta	Open / aceptado local
T03	T	Alteración del tráfico HTTP	Alta	Open / no aceptado
T04	T	Manipulación de trabajos por acceso DB	Alta	Open / no aceptado
T05	R	Borrado de auditoría por acceso privilegiado	Alta	Open / aceptado local
T06	R	Pérdida de trazabilidad de operaciones	Media	Open / no aceptado
T07	I	Exposición de secretos MFA y datos personales	Alta	Open / no aceptado
T08	I	Contraseña temporal en buzón	Alta	Open / aceptado local
T09	I	Robo de sesión por XSS	Alta	Open / aceptado local
T10	D	Agotamiento por login y MFA	Alta	Open / no aceptado

Aceptación con alcance limitado

Aceptar riesgo residual para la entrega académica/local no elimina la amenaza ni equivale a aprobación productiva. Una ejecución CI aprobada no cierra amenazas automáticamente.

3.4 Inventario STRIDE: T11-T20

ID	Cat.	Amenaza	Sev.	Estado / residual
T11	D	Acumulación de outbox por caída de Audit	Media	Open / aceptado local
T12	D	Trabajos abandonados / concurrencia	Media	Open / aceptado local
T13	E	Escalada entre roles o compañías	Alta	Mitigated / aceptado local
T14	E	Privilegios excesivos de servicios DB	Alta	Open / no aceptado
T15	E	Intento de restablecimiento MFA fuera de jerarquía/compañía	Alta	Mitigated / aceptado local
T16	T	Dependencias o imágenes comprometidas	Alta	Open / aceptado local
T17	E	Manipulación de permisos entre compañías/usuarios	Alta	Open / aceptado local
T18	S	Suplantación del canal panel↔permissions-grid	Alta	Open / aceptado local
T19	T	Manipulación de XLSX	Alta	Open / aceptado local
T20	D	Abuso de carga masiva	Alta	Open / aceptado local

T13: RBAC/multitenancy y pérdida inmediata de alcance, con 92 pruebas específicas. T15: jerarquía/compañía y revocación, con 29 pruebas. E18 conserva la validación local y la aceptación humana posterior. El CI f87243e repitió las 121 pruebas específicas con PostgreSQL efímero [R4, R13].

T13 trata administración de identidad; T17 trata concesiones de vistas. T09 se refiere a XSS; T18 al canal entre ventanas. T10 cubre login/MFA; T20 parsing/aprovisionamiento masivo. Estas distinciones evitan atribuir un control a amenazas diferentes.

3.5 Riesgo residual y tratamientos prioritarios

Grupo	Total	Decisión vigente
Mitigación técnica verificada	2	T13/T15: Mitigated; riesgo residual aceptado solo para alcance académico/local.
Open con riesgo aceptado local	12	T01/T02/T05/T08/T09/T11/T12/T16/T17/T18/T19/T20; mantienen limitaciones.
Open con riesgo no aceptado	6	T03/T04/T06/T07/T10/T14: tratamientos probados y laboratorio interactivo activo; revisión residual posterior pendiente.

Riesgo no aceptado	Tratamiento verificado y revisión pendiente
T03 - tráfico HTTP	TLS verificado y perfil interactivo activo; CA confiada para el usuario Windows. Desarrollo sigue HTTP. Revisar residual y entorno destino.
T04/T14 - privilegios DB	Seis logins mínimos activos en el laboratorio nuevo; sin DDL/escalada. Desarrollo conserva postgres; revisar alcance y residual.
T06 - trazabilidad	Reset MFA atómico probado en ambas rutas, rollback ante INSERT/COMMIT y alerta terminal. Otros eventos best-effort y operación de fallidos conservan límites.
T07 - secretos y PII	Archivos privados, claves separadas y backup cifrado/restaurado con MFA descifrable. Custodia, rotación y recuperación fuera del laboratorio pendientes.
T10 - login/MFA	Gateway probado con 30 solicitudes, 429 y cero 5xx; límites previos por cliente/global y concurrencia dos. No es carga distribuida/productiva.

Estos tratamientos ya tienen prueba técnica en el alcance descrito [R14, R15]. La aceptación residual del 13/10 y los estados Open se preservan; aprobar CI no sustituye una nueva decisión humana. Los límites de T20 y tráfico interno/operación permanecen documentados.

4. Pipeline DevSecOps

4.1 Integración continua y políticas de bloqueo

GitHub Actions ejecuta controles sobre push/PR y permite disparo manual o reutilización por CD. El espejo de yeisonfblopez permitió continuar las ejecuciones frente a las restricciones de Actions del repositorio principal. El código se sincroniza; los resultados remotos se atribuyen al repositorio ejecutor [R6, R7].

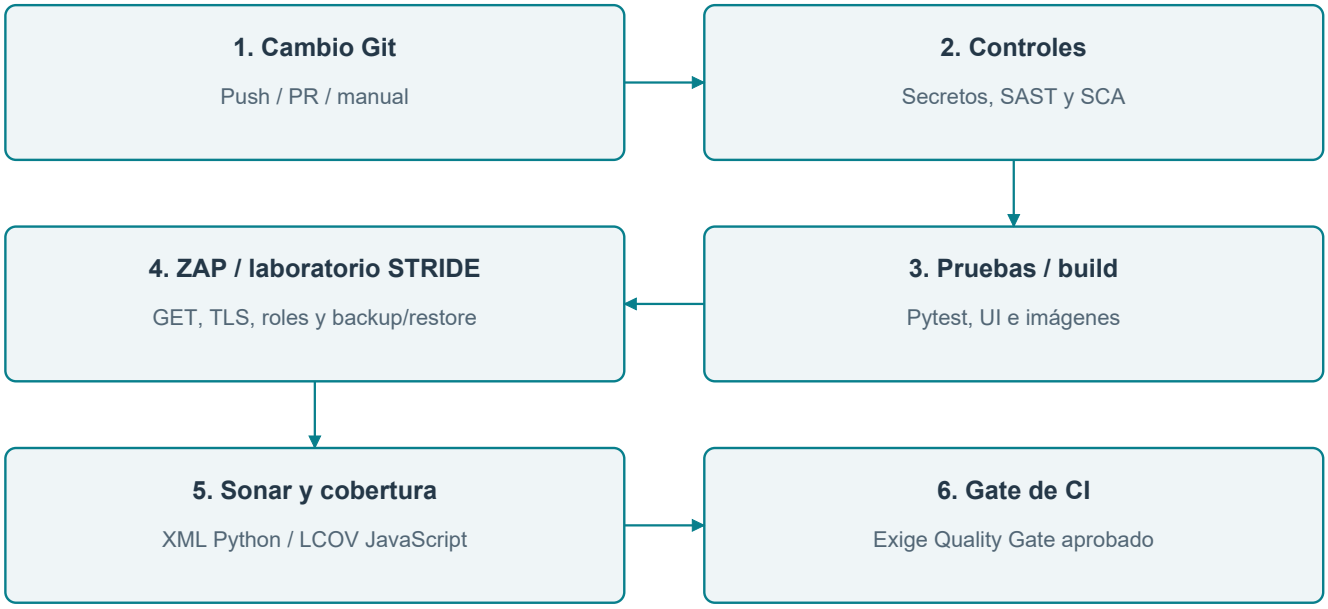


Figura 8. CI directo del espejo: pruebas/build, ZAP y laboratorio STRIDE en paralelo; Sonar combina cobertura propia, espera Quality Gate y el gate final exige aprobación. Los callers reutilizables de CD omiten Sonar explícitamente.

Control	Función / criterio
Gitleaks / Semgrep / Bandit	Secretos e historial; reglas de código y Python. Semgrep se ejecuta en Docker. Un fallo impide aprobar los controles requeridos.
SCA de dependencias	pip-audit/npm audit y Trivy de manifiestos/locks. Trivy SCA bloquea HIGH/CRITICAL, incluidas CVEs sin corrección.
Tests / frontend / modelos	Pytest, PostgreSQL aislado, UI Chromium, lint, configuración CSP y validación Threat Dragon. Los alcances son distintos.
Build y Trivy de imágenes	Construcción de imágenes y bloqueo CRITICAL. La prueba negativa de política no se interpreta como despliegue inseguro real.

4.2 ZAP automatizado y Quality Gate Sonar

El job zap-staging del espejo construye Identity, Permissions y Audit desde el checkout, en un proyecto nuevo, con DB iam_zap y secretos efímeros. No utiliza .env local, usuarios reales, SMTP ni Compose normal. No publica puertos de host [R6].

Etapa ZAP	Control verificado
Aislamiento previo	Contratos GET filtrados, rutas/métodos permitidos y gateway de alcance. El scanner no accede directamente a las APIs ni a DB.
Ejecución	7 scans; 39 operaciones/API-rol; 5 reglas activas LOW. Sin spider ni AJAX spider, con sesiones sintéticas.
Gate y completitud	MEDIUM/HIGH bloqueantes, sin alertas ignoradas. Se exige finalización por operación/rol/regla y acceso positivo a la aplicación.
Base y limpieza	Comparación de DB: solo actividad de sesión esperada. Limpieza del proyecto propio y paso always de respaldo; no docker prune global.
Reportes	HTML/JSON saneados, cobertura, gate y ciclo de ejecución; artefacto 30 días y evidencia seleccionada versionada con hashes.

Sonar del corte actual: Quality Gate aprobado

El análisis 61a1f7a aprobó el Quality Gate: nueva 85,6 % >= 80 %, global 56,7 %. Mantiene umbrales y reportes del mismo run. El resultado de E29 (88,1 %/54,5 %) conserva su corte histórico; el gate aprobado no elimina toda la deuda técnica [R13, R15].

El CI consolida XML Python de suites y scripts ejecutados, y LCOV de cinco módulos JavaScript, incluido el validador de orígenes de ventanas. El job stride-lab mide helpers, TLS/roles/MFA/auditoría, backup/restore y rate limit, además de escanear el gateway no root con Trivy. No acredita todo React ni cada proceso interno Docker [R15].

4.3 Publicación y despliegue simulado

La publicación histórica 1.0.0 construyó y escaneó imágenes antes de push y verificó tags/descargas por digest. El despliegue simulado usa Ansible y Compose sobre imágenes fijadas por digest; Checkov y políticas complementan las comprobaciones runtime [R7].

Evidencia	Resultado y límite
Docker Hub 1.0.0	Run 37574847806: 29 trabajos y 14 tags push/pull verificados. No representa automáticamente todos los cambios actuales.
Deploy del espejo	Run 38635912285: 33 aprobados y Sonar omitido (34 jobs), fuente d51902c. Despliega imágenes históricas 1.0.0 [R15].
IaC / runtime	Checkov con fixture negativa; 8 contenedores no root, HTTP y políticas runtime verificados. PostgreSQL sin puerto host en la simulación.
Idempotencia / persistencia	Segunda ejecución Ansible changed=0 y persistencia comprobada tras recrear PostgreSQL del entorno de prueba.
Instalación limpia	Segundo equipo iMac Intel: fuente 6d7e51c, secretos nuevos, build 7/7, migraciones, MFA, SMTP real, soporte y grilla. Corte independiente [R9].

El recibo R10 conserva la validación histórica del runtime local. Este corte sí cambia código común Identity/Permissions/dispatcher, migración 13 y compilación de orígenes del frontend. El runtime existente requiere aplicar migración 13 antes de reconstruir Permissions y reconstruir esos servicios conservando configuración/datos. La prueba limpia R15 acredita el perfil seguro independiente; el checkpoint registra la sincronización local posterior. No se publicó una nueva release Docker.

Reproducibilidad y entorno real

Build, instalación limpia, publicación y despliegue son evidencias diferentes. Un build no prueba SMTP real; un CD con 1.0.0 no despliega los cambios posteriores; una simulación sin TLS/HA no constituye producción real.

5. Resultados y tabla de hallazgos

5.1 Resultados cuantitativos y procedencia

Evaluación	Resultado	Alcance / referencia
CI del espejo	32/32 aprobados	61a1f7a; run 38638956405. Incluye laboratorio STRIDE, ZAP, cobertura y Quality Gate [R11, R15].
Sonar externo	Quality Gate passed	Nueva 85,6 % >= 80 %; global 56,7 %. 42 issues nuevos; cero aceptados. Recibo por analysisId y SHA evaluado [R12, R15].
ZAP final	7 scans / 39 API-rol / 1.947 solicitudes	0 hallazgos registrados; GET-only, 5 reglas LOW. DB sin cambios inesperados y limpieza confirmada [R6].
Seguridad Identity / Excel	183 seguridad + 86 Excel en CI	121 T13/T15 preexistentes, 14 T06 y 48 roles. Suites separadas y PostgreSQL nuevo; no sumar revisiones solapadas [R4, R15].
Cobertura medida CI	Python/LCOV propios del run	Sonar global 56,7 % y nueva 85,6 % son métricas distintas. Cinco módulos JavaScript; todo React no medido [R15].
SCA preservado	10/10 manifiestos; 2 MEDIUM	E24 sobre 8262da2: gate HIGH/CRITICAL aprobado. No se atribuye este conteo a d6c3440 [R8].
CD del espejo	33 success / 34 jobs; Sonar omitido	d51902c; release histórica 1.0.0 por digest, no nueva publicación. HTTP, UIDs y persistencia aprobados [R15].
Threat Dragon	20 amenazas	2 Mitigated y 18 Open: 12 con aceptación local y 6 no aceptadas [R3].
Instalación independiente	Build 7/7 y recorrido funcional	iMac Intel, 6d7e51c; secretos/base nuevos, SMTP real y persistencia [R9].

Las cifras de suites, cobertura, jobs y requests miden cosas distintas. No se suman pruebas históricas y actuales como si fueran una suite única; cero alertas ZAP no equivale a cero amenazas STRIDE.

5.2 Hallazgos de calidad y riesgos no aceptados

La tabla distingue observaciones de herramientas y riesgos del modelo. Prioridad de tratamiento no implica explotación demostrada. Las severidades Alta/Media proceden de STRIDE; Sonar y las brechas de entrega se expresan por su criterio propio.

ID / tipo	Hallazgo y evidencia	Severidad / estado	Tratamiento
H01 / calidad	Sonar nueva 85,6 % >= 80 %; check del corte aprobado [R15].	Cerrado en 61a1f7a	Mantener datos propios de cada revisión, umbrales y gate.
H02 / T03	TLS probado y laboratorio interactivo activo; desarrollo HTTP [R14-R16].	Alta / residual no aceptado	Completar primer acceso/MFA y revisar residual/destino; CA local autorizada.
H03 / T04 + T14	Seis logins mínimos activos en laboratorio; desarrollo conserva postgres [R14-R16].	Alta / residual no aceptado	Revisión residual del perfil; PostgreSQL sigue compartido.
H04 / T06	Reset/outbox atómicos y fallos INSERT/COMMIT probados; alerta de FALLIDO [R15].	Media / residual no aceptado	Actualizar runtime y operar fallidos; otros eventos best-effort mantienen límite.
H05 / T07	Secretos privados/independientes, clave TLS cifrada y backup restaurado [R15].	Alta / residual no aceptado	Custodiar claves originales; revisar rotación/offsite y entorno destino.
H06 / T10	Rate/concurrencia previos; 30 requests con XFF falso, 429 y cero 5xx [R15, R16].	Alta / residual no aceptado	Gateway activo en laboratorio; dimensionar y probar otro entorno/distribución.

H03 agrupa dos amenazas para evitar repetir el mismo tratamiento DB. No se confunden estos riesgos con alertas ZAP: el escaneo final no registró hallazgos en su alcance.

5.3 Hallazgos de alcance y deuda de cierre

ID / tipo	Observación	Estado y acción
H07 / SCA histórico	E24 conserva 2 MEDIUM sin bloqueantes HIGH/CRITICAL; corresponde a 10 manifiestos de ese corte [R8].	Revisar/actualizar tooling y advisories, manteniendo trazabilidad. No afirmar cero CVEs globales ni conteos actuales sin su reporte.
H08 / límite DAST	ZAP usa sesiones sintéticas y GET-only: no login/MFA, carga XLSX, POST/PUT/PATCH/DELETE ni descubrimiento frontend [R6].	Ampliar escenarios en laboratorio autorizado y con datos sintéticos. Las respuestas 403 y los rechazos del gateway no prueban lógica protegida.
H09 / release	Docker Hub 1.0.0 no contiene todos los cambios actuales [R7].	Decidir nueva versión; construir, escanear, publicar y validar el despliegue de esa versión.
H10 / cobertura global	Sonar global 56,7 %; LCOV de cinco módulos. E22/E29 conservan métricas anteriores [R5, R13, R15].	Ampliar React/global. Separar revisión y métrica; nueva 85,6 % no equivale al porcentaje de todo el proyecto.
H11 / entrega	Repositorios privados, capturas finales y video de 10-15 minutos pendientes [R1].	Resolver acceso para evaluación, preparar historia funcional y grabar sustentación. Este PDF consolida el informe técnico; no reemplaza el video.

Interpretación del resultado de ZAP

0 alertas en 1.947 requests es el resultado del laboratorio 61a1f7a definido. No elimina T09/T17/T18/T19/T20 ni demuestra ausencia de vulnerabilidades en flujos no ejecutados. Instalaciones CI corregidas históricamente y tratamientos STRIDE conservan alcances distintos [R15].

La aceptación humana mantiene 12 amenazas Open aceptadas solo en ámbito académico/local y T13/T15 Mitigated. T03/T04/T06/T07/T10/T14 tienen nuevos controles y pruebas en laboratorio, pero continúan sin una aceptación residual posterior. El perfil alternativo no endurece automáticamente el Compose de desarrollo [R14, R15].

5.4 Tratamientos verificados en laboratorio

Control	Resultado / evidencia
TLS y fronteras	Cuatro HTTPS con CA validada, TLSv1.3 observado, rechazo de CA desconocida, HTTP y host inválido. APIs/DB sin puertos directos.
Roles y bootstrap	Seis credenciales independientes; conexiones reales sin DDL/escalada ni lectura de MFA/credenciales ajenas. Bootstrap con iam_identity y runtimes no root.
Reset / auditoría	Ambas rutas atómicas; rollback ante INSERT/COMMIT, sin evento de éxito en denegaciones. Entrega real a Audit y alerta terminal sin payload.
Respaldo / restauración	Custom dump autenticado/cifrado; no plaintext en disco. DB de restore nueva/vacía, ACL reaplicadas y MFA descifrable con clave original.
Carga / XFF	30 solicitudes concurrentes; 429, cero 5xx; XFF falso no evita el bucket. Tasa 10/min cliente, global 30/s y concurrencia máxima dos.
Limpieza / integridad	Solo recursos del proyecto/volumen nuevo eliminados; contenedores normales preservados. Recibo limpio por SHA, artefactos saneados y hashes.

183 pruebas de Identity (121 anteriores, 14 T06 y 48 roles), 86 Excel, 28 helpers, 25 dispatcher con cuatro subtests y 24 Node pertenecen a suites distintas. Los datos son sintéticos y las credenciales efímeras; la contraseña, MFA, JWT, dump o claves no se archivan en los reportes públicos [R15].

El laboratorio interactivo iam-stride-demo-20261014 quedó activo desde bdedc77: cuatro HTTPS 200/TLSv1.3, nueve servicios no root, seis logins mínimos, backup inicial cifrado y 30 solicitudes/24 respuestas 429/cero 5xx. Los 28 contenedores previos, .env y conteos normales se preservaron. CA autorizada solo en CurrentUser/Root; cambio de contraseña/MFA pendientes del primer acceso humano [R16].

Decisión pendiente

Los seis riesgos conservan la decisión humana de no aceptación anterior. La evidencia permite una revisión posterior; no es aceptación automática. Desarrollo HTTP/DB administrativo, tráfico interno y eventos históricos best-effort no se declaran eliminados por el perfil probado.

5.5 Cobertura, integridad y evidencias consultadas

Servicio Python	Cobertura local	Sin cubrir / sentencias
Identity	64 %	778 / 2137
Permissions	96 %	7 / 170
Audit Service	86 %	25 / 178
Audit Dispatcher	77 %	41 / 176
Sync Worker	78 %	38 / 169

E22 conserva la cobertura histórica de cinco servicios, sin SHA original de ejecución. E29 conserva el primer cierre remoto 88,1 % nueva/54,5 % global. E32 acredita datos del nuevo run, con Sonar nueva 85,6 % y global 56,7 %; Python y LCOV miden sus propios alcances [R5, R13, R15].

Ref.	Documento / evidencia de origen
R1	README y requisitos
R2	Arquitectura y cuatro UML
R3	Threat Dragon, DFD y decisión STRIDE
R4	E18: integración local T13/T15
R5	Cobertura local y límites
R6	E26: ZAP y resultados CI/Sonar
R7	CI/CD del espejo y release histórico
R8	SCA: reportes preservados
R9	Instalación limpia en segundo equipo
R13	E29: cierre histórico de cobertura
R14	Perfil seguro, uso y límites
R15	E32: STRIDE y CI/Sonar del nuevo corte
R16	E34: activación interactiva y confianza local

R10. Recibo local histórico d6c3440: configuración/datos preservados. R11. CI y artefactos actuales: 61a1f7a, 32 jobs. R12. Check Sonar aprobado: mismo SHA. E32 conserva laboratorio, métricas y hashes.

El código se enlaza al corte 61a1f7a. E31 identifica la preparación local dirty y sus hashes; E32 conserva el run limpio probado. Las evidencias archivadas después del análisis se consultan en master con recibo por SHA. E28/E30 mantienen PDFs históricos. Repositorios privados; no se incluyen secretos, JWT ni datos personales reales.

6. Conclusiones

6.1 Balance técnico

IAM Secure implementa una base funcional de gobierno de identidades y accesos: autentica con contraseña y MFA, conserva sesiones revocables y aplica roles y compañía en servidor. Permissions separa concesiones de vistas, y la carga Excel reutiliza el aprovisionamiento con validación previa y resultados persistidos.

El corte 61a1f7a aprobó 32 trabajos CI y Quality Gate Sonar. Mantiene secretos/SAST/SCA/tests/build/Trivy y ZAP GET-only, y agrega el laboratorio TLS/roles/MFA/auditoría/backup/restore/carga. ZAP conserva alcance explícito; el laboratorio no se presenta como producción [R15].

El resultado exige interpretación por alcance. Las pruebas locales T13/T15 verificaron controles concretos; la instalación independiente demuestra reproducibilidad del corte ejecutado; el despliegue 1.0.0 no representa automáticamente la aplicación actual. El escaneo GET-only no cubre todas las funciones ni sustituye la decisión de riesgo STRIDE.

El Quality Gate aprobó con cobertura nueva 85,6 % frente a 80 % mínimo y global 56,7 %. Los tratamientos STRIDE incluyen roles mínimos, reset atómico, TLS, backup cifrado/restaurable y rate limit. E34 registra su activación interactiva local con datos nuevos y CA autorizada. Restan primer acceso/cambio de contraseña/MFA y revisión residual humana; la activación no implica aceptación [R14-R16].

6.2 Cierre priorizado y alcance de la entrega

Prioridad	Siguiente acción y criterio de cierre
1. Acceso y revisión residual	Completar primer acceso, cambio de contraseña/MFA del laboratorio activo; revisar T03/T04/T06/T07/T10/T14 y registrar decisión humana local.
2. Calidad remota	Mantener el Quality Gate aprobado por revisión; ampliar cobertura global y componentes React y priorizar deuda técnica.
3. Release y alcance DAST	Validar nueva release si se publica; ampliar login/MFA, Excel, escritura y frontend en un laboratorio con alcance explícito.
4. Entrega académica	Resolver acceso al repositorio, completar capturas e historia funcional y grabar video. El informe técnico queda consolidado en este PDF.

La entrega constituye una solución académica/local trazable, con avances verificados y límites explícitos. Su transición a producción requiere los tratamientos pendientes, políticas operativas y validación del entorno destino; no se declara una plataforma productiva totalmente cerrada.